

## **NARRATIVA EXPLICATIVA**

### **El Por Qué y el Para Qué de la Encuesta MSS**

#### **Contexto, Urgencia y Propósito Estratégico**

##### **Versión 1.0 — Abril 2026**

*"Medir la ciberseguridad no es un fin en sí mismo: es el mapa que impide que la expedición se pierda en el bosque de los incidentes que nadie había anticipado."*

### **PRÓLOGO: EL MOMENTO EN QUE LA CIBERSEGURIDAD DEJÓ DE SER «COSA DE INFORMÁTICA»**

Hay momentos históricos que solo se entienden en perspectiva. La entrada en vigor del Reglamento (UE) 2025/37 el 4 de febrero de 2025, que define formalmente los Servicios de Seguridad Gestionados (MSS) en el derecho europeo, no fue uno de esos momentos que aparecen en titulares de prensa generalista. Y sin embargo, su alcance es considerable: por primera vez, el ecosistema de empresas que gestionan la ciberseguridad de otras organizaciones queda sometido a un régimen de supervisión, certificación y accountability que antes era voluntario, fragmentado y prácticamente imposible de comparar entre países.

Este instrumento de encuesta nace en ese preciso cruce de caminos: entre la urgencia regulatoria que obliga a medir y la realidad operativa que frecuentemente ignora que existe algo que medir.

#### **I. LA PARADOJA DEL MERCADO QUE CRECE Y NO SE MIDE**

El mercado global de MSS alcanzó en 2025 entre 38.000 y 67.000 millones de dólares según la metodología de segmentación utilizada, con tasas de crecimiento anual compuesto (CAGR) de entre el 11,5% y el 12,5%. En España, el mercado de ciberseguridad rozó los 4.600 millones de dólares en 2025, con expectativas de superar los 7.900 millones antes de 2030.

Estos son números impresionantes que sugieren un sector en plena maduración. Y sin embargo, el análisis de mercado MSS de ENISA de junio de 2025 revela una paradoja perturbadora: el 86% de las organizaciones que contratan MSS exigen personalización en sus métricas y SLAs, pero solo el 24% lo consigue. Del lado de los proveedores, ese porcentaje de oferta real de personalización métrica cae a cero estadístico.

En otros términos: el mayor mercado de seguridad gestionada de la historia está siendo comprado y vendido casi sin indicadores relevantes, con SLAs genéricos que miden lo que es fácil de medir (número de tickets, disponibilidad del portal, horas de soporte) en lugar de lo que importa (tiempo hasta detectar al atacante, tiempo hasta contenerlo, porcentaje real de activos monitorizados).

Esta encuesta es, en primer lugar, una herramienta para romper esa paradoja. Para permitir que las organizaciones sepan qué preguntar, qué exigir y qué medir en sus contratos MSS.

## II. ESPAÑA EN EL OJO DEL HURACÁN REGULATORIO

La España de 2026 es un laboratorio peculiar de gestión del riesgo ciber. Por un lado, INCIBE gestionó 122.223 incidentes en 2025, un 26% más que el año anterior, con 237.028 sistemas vulnerables detectados proactivamente por la agencia nacional. Por otro, el gobierno aprobó en mayo de 2025 un plan de inversión en ciberseguridad de 1.157 millones de euros — el mayor de la historia del país —, con asignaciones para Defensa, Interior, el Ministerio de Transformación Digital y el Departamento de Seguridad Nacional.

Simultáneamente, España acumula un retraso de más de 16 meses en la transposición de la Directiva NIS2. El anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad, que crea el Centro Nacional de Ciberseguridad (CNCS) como autoridad única, fue aprobado por el Consejo de Ministros en enero de 2025 y esperaba a la fecha de este informe su tramitación parlamentaria.

Esta tensión entre la urgencia real de la amenaza y la lentitud de la respuesta institucional no es exclusiva de España: refleja la brecha estructural entre la velocidad del mundo digital y el ritmo de la legislación. Lo que sí es peculiar del contexto español es la combinación de tres factores:

1. Posición geoestratégica de hub digital: España es punto de conexión de cables submarinos hacia África y Latinoamérica, con implicaciones directas en el atractivo del país como objetivo de ciberataques con motivaciones geopolíticas.
2. Concentración sectorial del riesgo: El 34% de los incidentes en operadores esenciales afectan al sector bancario, mientras que agroindustria y logística operan con niveles de madurez muy inferiores a los recomendados.
3. Ecosistema proveedor con soberanía parcial: El 51% de los MSSPs que operan en Europa están bajo control de entidades no europeas, pese a tener sede en la UE — una dependencia estratégica que ningún indicador operativo convencional captura.

La encuesta MSS está diseñada para capturar estas tres dimensiones y producir un diagnóstico que sea útil no solo para las organizaciones individuales, sino para los responsables de políticas públicas y los reguladores que trabajan en construir el ecosistema de seguridad gestionada que España necesita.

## III. POR QUÉ LOS INDICADORES SON EL PROBLEMA Y LA SOLUCIÓN

*"Lo que no se mide, no se puede gestionar; lo que no se gestiona, empeora sistemáticamente."*

Esta máxima, atribuida habitualmente a Peter Drucker aunque con variantes filosóficas de gran tradición, tiene en ciberseguridad una precisión casi quirúrgica. El MTTD (Mean Time to Detect) —el tiempo desde que comienza la actividad maliciosa hasta que el sistema lo detecta— es el indicador que separa a las organizaciones que sobrevivirán a un incidente de ransomware de las que no.

CrowdStrike documentó en 2025 que los atacantes comprometían un sistema en un promedio de 48 minutos desde el acceso inicial. Si el MTTD de una organización se mide en días (la realidad más

frecuente en organizaciones de madurez media-baja), el atacante ha tenido tiempo suficiente para moverse lateralmente por la red, elevar privilegios, exfiltrar datos y cifrar sistemas antes de que nadie haya levantado una ceja.

Pero hay un segundo nivel del problema, más profundo: muchas organizaciones no miden el MTDD no porque no quieran, sino porque sus contratos MSS no incluyen esa métrica. Y muchos MSSPs no la incluyen no porque no puedan medirla, sino porque, convenientemente, nadie se la ha exigido.

La encuesta es, por tanto, un instrumento de empoderamiento del comprador de MSS: le ayuda a saber qué métricas debería exigir, qué valores debería esperar de ellas, y cómo posicionarse respecto al mercado y a los requisitos regulatorios.

#### **IV. LAS CINCO PREGUNTAS QUE VERTEBRAN EL INSTRUMENTO**

Más allá de la estructura técnica de bloques y preguntas, la encuesta está diseñada para responder cinco preguntas estratégicas sobre cada organización:

##### **Pregunta Estratégica 1: ¿Sabe esta organización lo que tiene?**

*(Bloques B0, B6, B8)*

El inventario de activos es el prerequisite de cualquier programa de seguridad. No se puede proteger lo que no se conoce, no se puede monitorizar lo que no está inventariado, y no se puede medir el ACR (Asset Coverage Ratio) sin saber cuántos activos existen. La brecha del «shadow IT» —tecnología no inventariada— es uno de los vectores de compromiso más frecuentes en organizaciones españolas de tamaño medio.

##### **Pregunta Estratégica 2: ¿Puede detectar al atacante antes de que cause daño irreversible?**

*(Bloque B3)*

Esta es la pregunta central del paradigma de detección y respuesta moderno. El MTDD, el MTTC y el MTTR no son métricas abstractas: son la diferencia entre un incidente contenido y uno que acaba en portada de periódico. La encuesta evalúa tanto si se miden como si los valores obtenidos son aceptables en el contexto del sector y del perfil de amenaza.

##### **Pregunta Estratégica 3: ¿Está preparada para sobrevivir al incidente que inevitablemente llegará?**

*(Bloque B5)*

La ciberseguridad perfecta es un ideal platónico. La resiliencia real —la capacidad de mantener la continuidad del negocio durante y después de un incidente significativo— es lo que distingue a las organizaciones maduras de las que aprenden la lección de la forma más costosa posible. Los BCP con escenarios ciber, los RTO/RPO verificados y los simulacros regulares son los termómetros de esa resiliencia.

##### **Pregunta Estratégica 4: ¿Conoce su exposición financiera al ciberriesgo?**

*(Bloque B9)*

Un CISO que no puede cuantificar el riesgo en euros ante la Alta Dirección tiene pocas posibilidades de obtener el presupuesto que necesita. El ROSI (Return on Security Investment), el modelo actuarial de ciberriesgo y el ciberseguro son las tres herramientas de traducción del riesgo técnico al lenguaje del negocio. El mercado español de ciberseguros creció un 12% en 2025 hasta 190 millones de euros — señal de que el mercado está madurando; señal también de que el riesgo real que justifica esas primas no está desapareciendo.

### **Pregunta Estratégica 5: ¿Está preparada para las amenazas que aún no existen en los SLAs actuales?** (Bloque B10)

La computación cuántica, la IA generativa ofensiva, los ataques a agentes autónomos de IA, la explotación de vulnerabilidades en entornos OT/ICS: las amenazas de 2027 no están en los contratos MSS firmados en 2024. La encuesta evalúa la preparación de las organizaciones para estos horizontes emergentes, incluyendo la transición hacia criptografía postcuántica — un proceso que no tiene marcha atrás y cuyo reloj ya está corriendo.

## **V. EL TONO: IRONÍA AL SERVICIO DE LA VERDAD**

Las personas que rellenan encuestas de cumplimiento normativo tienen, en general, una relación íntima con la deseabilidad social. Cuando la respuesta «correcta» es evidente, la tendencia natural es elegirla, independientemente de lo que realmente ocurre en la organización.

Este instrumento ha sido diseñado con un principio metodológico diferente: hacer que las respuestas honestas —incluidas las desfavorables— sean formuladas con un lenguaje que no criminalice sino que reconozca la realidad con ecuanimidad y cierto sentido del humor. La diferencia entre *"No disponemos de ciberseguro"* y *"No disponemos de ciberseguro, ni lo hemos considerado necesario hasta ahora"* es sutil en la forma pero significativa en la función: la segunda opción reconoce una posición conscientemente tomada, no solo una omisión.

Esta elección narrativa responde a la investigación sobre sesgo de respuesta en instrumentos de autoevaluación organizacional: cuando las opciones desfavorables están redactadas de forma neutra o levemente irónica (sin ser burlescas), la tasa de honestidad del respondente aumenta significativamente respecto a formulaciones que implican juicio moral o incompetencia.

La ironía, bien utilizada, no es un adorno retórico: es una herramienta epistemológica.

## **VI. CÓMO LEER LOS RESULTADOS: UNA ADVERTENCIA HONESTA**

El IGM-MSS que produce esta encuesta es un indicador de diagnóstico, no un certificado de seguridad. Una puntuación alta no significa que la organización sea inmune a los incidentes — tal inmunidad no existe. Significa que la organización tiene los fundamentos metodológicos, tecnológicos y de gobernanza que aumentan significativamente su capacidad de detectar, contener y recuperarse de los incidentes que ocurrirán.

Inversamente, una puntuación baja no es un veredicto de culpabilidad. Es un mapa de brechas que permite priorizar inversiones, negociar mejor los contratos MSS y construir un argumento sólido ante la Alta Dirección para obtener los recursos necesarios.

El valor real de esta encuesta no está en el número final del IGM-MSS. Está en las conversaciones que provoca: entre el CISO y el CEO, entre el responsable de cumplimiento y el proveedor MSS, entre el gestor de riesgos y el consejo de administración. Si esta encuesta consigue que se formulen las preguntas correctas en los lugares correctos, habrá cumplido su función con creces.

## VII. EPÍLOGO: EL PRÓXIMO PASO SIEMPRE ES EL PRIMERO

La ciberseguridad tiene una propiedad irritante: el nivel de amenaza no espera a que el nivel de madurez organizacional lo alcance. Los 122.223 incidentes que gestionó INCIBE en 2025 no anunciaron su llegada con cortesía burocrática. El ransomware no pide turno.

Por eso, más allá del rigor metodológico y la sofisticación de los indicadores, esta encuesta tiene un propósito sencillo y ambicioso a la vez: que quien la complete salga con más claridad sobre dónde está, más honestidad sobre lo que falta, y más convicción sobre lo que hay que hacer primero.

En ciberseguridad, como en la montaña, el mapa no garantiza que no te perderás. Pero sin mapa, la probabilidad de encontrar el camino correcto depende enteramente de la suerte. Y la suerte, como todo actuario sabe, es una estrategia de riesgo con ROSI negativo a largo plazo.

*Narrativa Explicativa — Versión 1.0 · Abril 2026*

*Consorcio MSS: CISO · Criptógrafo Cuántico · Arquitecto Zero Trust · Actuario de Riesgo Ciber · Estratega de Resiliencia Digital*